

개인정보 보호법 위반에 대한 과태료 부과기준

제1조(목적) 이 고시는 「개인정보 보호법」(이하 "법"이라 한다) 제75조, 같은 법 시행령(이하 "령"이라 한다) 제63조 및 [별표 2]에 규정된 위반행위에 대한 과태료 부과 절차와 기준에 관하여 필요한 사항을 정함을 목적으로 한다.

제2조(정의) 이 고시에서 사용하는 용어의 뜻은 다음과 같다.

1. "위반행위"란 법을 위반하여 법 제75조의 과태료 부과 대상이 되는 행위를 말한다.
2. "기준금액"이란 영 [별표 2] 개별기준의 각 목별 위반행위에 대하여 위반횟수별로 규정된 과태료 금액을 말한다.
3. "조정금액"이란 위반행위의 정도, 위반행위의 동기와 그 결과 등을 고려하여 각 위반행위별 기준금액에 제6조 또는 제7조에 따라 감경 또는 가중하는 금액을 말한다.
4. "과태료 부과금액"이란 기준금액에 조정금액을 가산 또는 차감하여 최종적으로 위반행위자에게 부과하는 과태료 금액을 말한다.

제3조(과태료의 면제) ① 위반행위가 다음 각 호의 어느 하나에 해당하는 경우에는 과태료를 부과하지 아니한다.

1. 「질서위반행위규제법」 제7조에서 정한 바와 같이 당사자의 고의 또는 과실이 없는 경우
2. 「질서위반행위규제법」 제8조에서 정한 바와 같이 당사자의 질의

에 대한 담당 공무원의 서면회신이나 행정지도 기타 공적인 견해표명 등에 의하여 자신의 행위가 위법하지 아니한 것으로 오인하고 행한 행위로서 그 오인에 정당한 사유가 있는 경우

3. 「질서위반행위규제법」 제9조에서 정한 바와 같이 14세가 되지 아니한 자의 위반행위

4. 「질서위반행위규제법」 제10조제1항에서 정한 바와 같이 심신(心神)장애로 인하여 행위의 옳고 그름을 판단할 능력이 없거나 그 판단에 따른 행위를 할 능력이 없는 자의 위반행위. 다만 스스로 심신장애 상태를 일으켜 질서위반행위를 한 자에 대하여는 그렇지 않다.

② 다음 각 호의 어느 하나에 해당하는 경우에는 과태료를 부과하지 않을 수 있다. 다만, 본문에 따라 과태료 부과처분을 받지 않은 자가 그 결정이 있는 날부터 3년 이내에 같은 위반행위를 하는 경우에는 그렇지 않다.

1. 위반행위의 내용·정도가 경미하거나 사소한 부주의나 오류로 인한 위반행위인 경우

2. 정보주체에게 피해가 발생하지 아니하였거나 경미한 경우로서 위반행위를 시정한 경우

3. 위반행위자가 「소상공인기본법」 제2조에 따른 소상공인인 경우 등인 경우로서 부과하고자 하는 과태료 금액이 위반행위자의 현실적인 부담능력을 벗어나 과중하다고 인정되는 경우

4. 제1호부터 제3호까지에 준하는 사유가 있어 과태료 부과 면제가

불가피하다고 인정되는 경우

제4조(과태료의 부과기준) ① 과태료 부과금액은 영 [별표 2]에 따른 각 위반행위별 기준금액에 조정금액을 가산하거나 차감하여 결정한다.

$\text{과태료 부과금액} = \text{기준금액} \pm \text{조정금액}$

② 조정금액은 제6조와 제7조에서 정한 감경 또는 가중 사유가 인정되는 경우 다음과 같이 산정한다.

$\begin{aligned} \text{조정금액} &= \text{가중금액} - \text{감경금액} \\ \text{가중금액} &= \text{위반행위별 기준금액} \times \text{가중비율의 합계} \\ \text{감경금액} &= \text{위반행위별 기준금액} \times \text{감경비율의 합계} \end{aligned}$
--

③ 하나의 행위가 2개 이상의 위반행위에 해당하는 경우에는 각 위반행위에서 정한 과태료 중 가장 중한 과태료를 부과한다.

④ 2개 이상의 위반행위가 경합하는 경우에는 각 위반행위에 대하여 정한 과태료를 각각 부과한다.

제5조(기준금액의 산정) 최근 3년간 같은 위반행위로 과태료 처분을 받았거나 「비송사건절차법」에 따른 과태료 재판 결정을 받은 위반횟수를 확인하고 위반횟수별 해당 과태료 금액을 기준금액으로 한다. 이 경우 기준금액을 산정할 때 영 [별표 2] 제1호 가목·나목에 따른 가중된 부과처분의 적용 순서도 및 예시는 [별표 1]과 같다.

제6조(과태료의 감경) ① 개인정보 보호위원회(이하 "보호위원회"라 한다)는 당사자의 위반행위의 정도, 위반행위의 동기와 그 결과 등을 고

려하여 [별표 2]의 감경기준에 따라 기준금액의 100분의 50의 범위 이내에서 감경할 수 있다. 다만, 과태료를 체납하고 있는 경우는 제외한다.

② [별표 2]의 각 기준에 따른 과태료 감경 시 그 사유가 2개 이상 해당되는 경우에는 합산하여 감경하되, 제2호 1) 및 2)에 해당하는 사유가 각 2개 이상 해당되는 경우에는 기준금액의 100분의 50을 초과할 수 없고, 최종 합산 결과 기준금액의 100분의 90을 초과할 수 없다.

제7조(과태료의 가중) ① 보호위원회는 당사자의 위반행위의 정도, 위반행위의 동기와 그 결과 등을 고려하여 [별표 3]의 가중기준에 따라 기준금액의 100분의 50의 범위 이내에서 가중할 수 있다.

② [별표 3]의 각 기준에 따른 과태료 가중 시 그 사유가 2개 이상 해당되는 경우에는 합산하여 가중하되, 기준금액의 100분의 50을 초과할 수 없다.

제8조(과태료 부과금액의 결정) 위반행위별 과태료 금액이 법 제75조 제1항부터 제4항까지의 규정에 따른 과태료 금액의 상한을 넘는 경우에는 과태료 금액의 상한을 과태료 부과금액으로 한다.

제9조(자진납부자에 대한 과태료 감경) 보호위원회로부터 과태료 고지서를 송달받은 날부터 14일 이내에 과태료를 납부하는 자에 대해서는 「질서위반행위규제법」 제18조 및 같은 법 시행령 제5조를 준용하여 해당 과태료 부과금액의 100분의 20을 감경한다.

부 칙

제1조(시행일) 이 고시는 2026년 9월 11일부터 시행한다.

제2조(적용례) ① 이 고시는 이 고시 시행 전에 종료된 위반행위에 대해서도 적용한다.

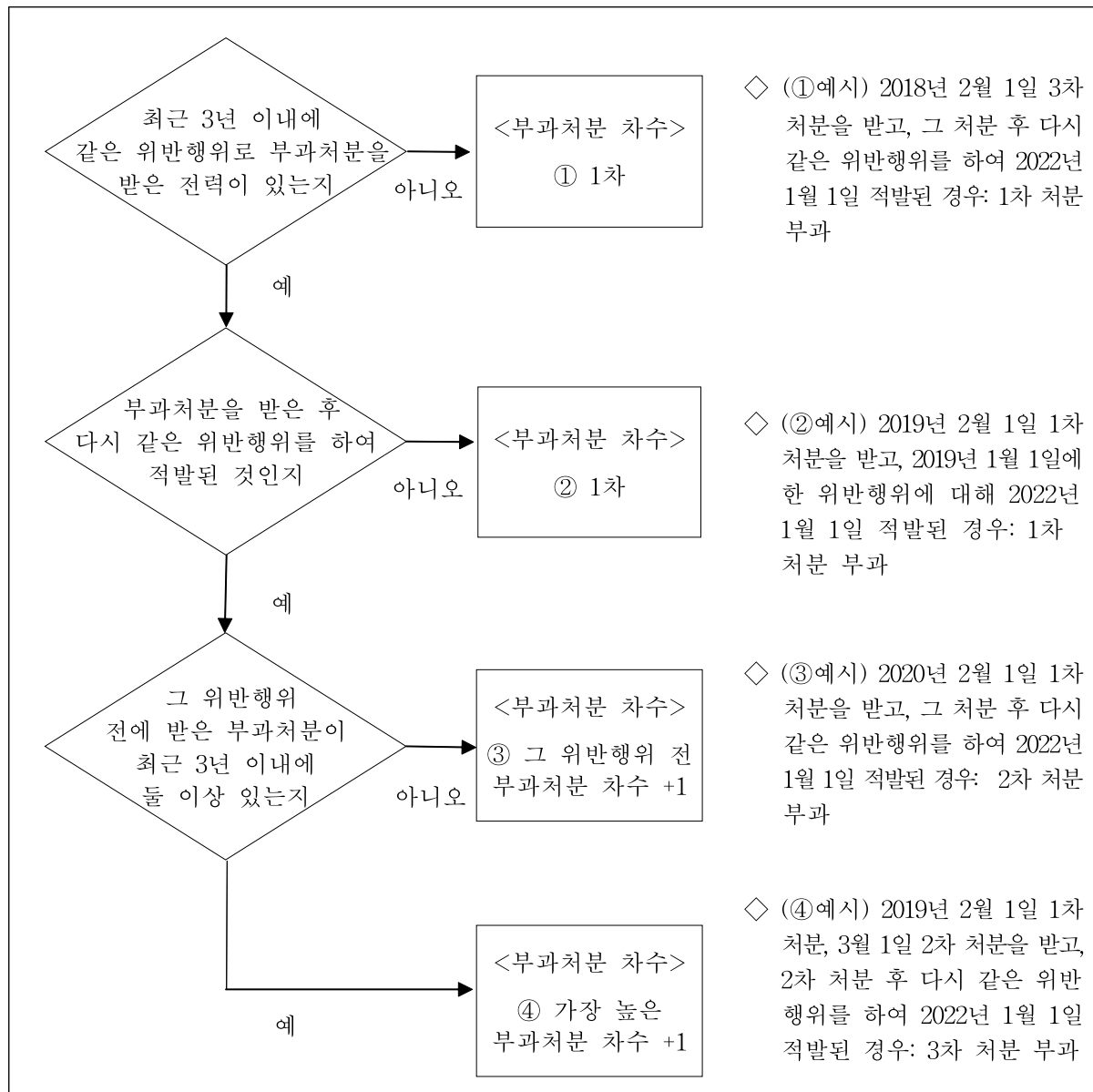
② 별표 2의 피해 확산 방지 규정은 이 고시 시행 이후 종료된 위반행위부터 적용한다.

제3조(경과조치) ① 이 고시 시행 전에 종료된 위반행위에 대해서는 별표 2의 개정규정에도 불구하고 종전의 「개인정보 보호법 위반에 대한 과태료 부과기준(2023.9.11.)」에 따른 감경비율을 적용한다.

② 2023년 9월 15일 전에 종료된 위반행위에 대해서는 이 고시에 따른 기준과 종전의 「개인정보 보호법 위반에 대한 과태료 부과기준(2023.3.8.)」에 따른 기준 중 위반행위자에게 유리한 기준을 적용한다.

[별표 1]

가중처분 적용 순서도 및 예시(제5조 관련)



[별표 2]

과태료의 감경기준(제6조 관련)

1. 위반행위자에 대하여 제2호에서 정한 감경사유가 인정되는 경우에는 각 감경사유별 감경비율의 범위 내에서 감경할 수 있다.

2. 과태료의 감경기준은 다음과 같다.

1) 당사자 환경 및 위반 정도 등 : 기준금액의 50% 이내

기준	감경사유	감경비율
당사자 환경 * 근거: 「질서위반행위규제법 시행령」 제2조의2	1. 「국민기초생활 보장법」 제2조에 따른 수급자 2. 「한부모가족 지원법」 제5조 및 제5조의2제2항·제3항에 따른 보호대상자 3. 「장애인복지법」 제2조에 따른 장애인 중 장애의 정도가 심한 장애인 4. 「국가유공자 등 예우 및 지원에 관한 법률」 제6조의4에 따른 1급부터 3급까지의 상이등급 판정을 받은 사람 5. 14세 이상 19세 미만의 미성년자 6. 「질서위반행위규제법」 제10조제2항에 따른 심신장애자 * 다만 스스로 심신장애 상태를 일으켜 위반행위를 한 자는 제외한다.	기준금액의 50% 이내
위반 정도	※ 상기 1.~5. 항목에 해당하여 감경 시 「질서위반행위규제법」 제18조에 따른 자진납부자 감경을 제외하고 하단 사유로 추가 감경 불가 위반행위의 내용·정도가 경미하다고 인정되거나 사소한 부주의나 오류로 인한 위반행위로 인정되거나 정보주체에게 피해가 발생하지 아니하였거나 경미한 경우로서 면제에 이르지 아니한 경우	기준금액의 30% 이내
개인	1. 위반행위자가 비영리법인, 비영리단체 등인 경우로서 무보수	기준금액의

정보 처리	성, 공익성, 비영리성 등을 고려할 때 과중하다고 인정되는 경우	30% 이내
자의 업무	2. 「중소기업기본법」 제2조에 따른 소기업(小企業)인 경우	기준금액의 30% 이내
형태 및 규모	3. 「중소기업기본법」 제2조에 따른 중기업(中企業)인 경우	기준금액의 15% 이내

2) 개인정보 보호 노력, 조사 협조·자진 시정 등 : 기준금액의 50% 이내

(1) 개인정보 보호를 위한 노력 정도

기준	감경사유	감경비율
개인 정보 보호 인증	1. 위반행위자가 법 제32조의2에 따른 개인정보 보호 인증(ISMS-P)을 받은 경우 * 유효한 PIMS 인증 등을 포함한다.	기준금액의 30% 이내
	2. 위반행위자가 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제47조제2항 각 호의 어느 하나에 해당하지 아니하는 자로서 정보보호 관리체계 인증(ISMS)을 받은 경우	기준금액의 20% 이내
	3. 개인정보 보호 관련 국제인증(ISO27701)을 받은 경우	기준금액의 20% 이내
	4. 개인정보 보호 관련 국제인증(ISO27001, BS10012)을 받은 경우	기준금액의 20% 이내
	5. 위반행위자가 민간자율의 개인정보 보호 마크 인증(ePRIVACY P LUS, PRIVACY 등)을 받은 경우	기준금액의 10% 이내
	※ 상기 1.~5. 항목은 인증범위 내에 위반행위가 발생한 개인정보처리시스템이 있는 경우에만 적용한다.	
	※ 상기 1.~5. 항목 중 두 가지 이상에 해당하는 경우에는 가장 높은 감경비	

	율을 적용한다.	
자율 규제 규약 등	개인정보 보호 자율규제 규약을 이행하는 등 개인정보 보호 활동을 성실히 수행한 것으로 확인된 경우	기준금액의 40% 이내
개인 정보 보호 활동	1. 개인정보 처리방침의 평가의 결과가 상위 등급인 경우	기준금액의 10% 이내
	2. 개인정보 보호수준 평가의 결과가 상위 등급인 경우	기준금액의 10% 이내
	3. 개인정보 영향평가를 하는 등 개인정보 보호 활동을 성실히 수행한 것으로 확인된 경우 * 다만, 법 제33조제1항에 따라 개인정보 영향평가를 해야 하는 경우는 제외	기준금액의 10% 이내
	4. 개인정보 보호책임자 및 개인정보취급자의 업무에 요구되는 전문적인 교육훈련을 정기적으로 성실히 수행하거나 표창을 받는 등 개인정보 보호를 위한 노력이 상당히 있는 경우	기준금액의 5% 이내
	※ 상기 1.~2. 항목은 가장 최근에 시행한 평가 결과를 반영하고, 상기 2.~3. 항목은 평가범위 내에 위반행위가 발생한 개인정보처리시스템이 있는 경우에만 적용한다. ※ 상기 1.~4. 항목 중 두 가지 이상에 해당하는 경우에는 가장 높은 감경비율을 적용한다.	

※ 비고 : "민간자율의 개인정보 보호 마크 인증(ePRIVACY PLUS, PRIVACY 등)"이란 개인정보를 수집·처리하는 기관 등을 대상으로 개인정보 보호 적정성 등 50개 이상의 심사항목에 따라 심사·인증하는 제도(OPA 등 법상 민간자율단체 부여)

(2) 조사 협조, 자진 시정 등

기준	감경사유	감경비율
조사 협조	보호위원회의 조사기간 중에 일관되게 행위사실을 인정하면서 위법성 판단에 도움이 되는 자료를 제출하거나 진술하는 등 조 사에 적극 협력한 경우	기준금액의 20% 이내
자진 시정 등	1. 과태료의 사전통지 및 의견제출 기간이 종료되기 이전에 위 반행위를 중지하는 등 시정을 완료한 경우	기준금액의 20% 이내
	2. 사전통지 및 의견제출 기간 내에 법규 위반행위를 시정 완료 하지는 못하였으나 시정 중에 있는 것으로 인정되는 경우	기준금액의 10% 이내
피해 회복	개인정보 분쟁조정, 민사조정 등을 통해 정보주체에게 발생한 피해에 대한 원상회복, 손해배상 또는 이에 상당하는 필요한 피 해의 회복 조치를 이행한 경우	기준금액의 30% 이내
피해 확산 방지	개인정보 유출등 사고 발생에 대비한 대응 체계를 구축·운영하 고 그에 따라 사고 발생 시 조기 탐지, 신속한 신고·통지 및 피 해확산 방지 조치의 이행 등 안전한 보호체계로 신속하게 회복· 개선한 경우	기준금액의 40% 이내
자진 신고	위반행위 사실을 자진신고 한 경우 * 다만, 법 제34조제3항 전단에 따른 신고는 제외	기준금액의 20% 이내

[별표 3]

과태료의 가중기준(제7조 관련)

1. 위반행위자에 대하여 제2호에서 정한 가중사유가 인정되는 경우에는 각 가중사유별 가중비율의 범위 내에서 가중할 수 있다.

2. 과태료의 가중기준은 다음과 같다.

기준	가중사유	가중비율
위반의 정도	1. 제3호 위반행위별 각 목의 세부기준에서 정한 행위가 3개 이상에 해당하는 경우	기준금액의 30% 이내
	2. 제3호 위반행위별 각 목의 세부기준에서 정한 행위가 2개에 해당하는 경우	기준금액의 15% 이내
위반 기간	1. 법 위반 상태의 기간이 2년을 초과하는 경우	기준금액의 30% 이내
	2 법 위반 상태의 기간이 1년 초과 2년 이내인 경우	기준금액의 15% 이내
조사 방해	위반행위자 및 그 소속 임직원이 법 제63조제1항 및 제2항에 따른 물품·서류의 제출요구 또는 검사를 거부하거나 증거인멸, 은폐, 조작, 허위의 정보제공 등의 방법으로 조사를 방해하거나, 관련 정보주체 등에게 허위로 진술하도록 요청한 경우 * 다만, 법 제63조제1항·제2항에 따른 물품·서류의 제출요구 또는 검사를 거부·방해 또는 기피한 행위(법 제75조제2항제25호·제26호)로 과태료를 부과 받은 경우에는 가중하지 아니한다.	기준금액의 50% 이내
위반 주도	다수의 위반행위자가 관련된 상황에서 위반행위를 주도하거나 선도한 경우	기준금액의 20% 이내

3. 제2호 가중사유의 위반행위별 각 목의 세부기준은 아래와 같다.

위반행위별	세부기준
영 별표2 제2호 아목	법 제23조제2항·제24조제3항·제25조제6항(제25조의2제4항에 따라 준용되는 경우를 포함한다)·제28조의4제1항·제29조(제26조제8항에 따라 준용되는 경우를 포함한다)에 따른 안전성 확보에 필요한 조치로서, <개인정보처리자의 경우> 가. 영 제30조제1항제1호에 따라 개인정보의 안전한 처리를 위한 내부 관리계획의 수립·시행 및 점검을 하지 않은 경우 나. 영 제30조제1항제2호에 따라 개인정보에 대한 접근 권한을 제한하기 위한 조치를 하지 않은 경우 다. 영 제30조제1항제3호에 따라 개인정보에 대한 접근을 통제하기 위한 조치를 하지 않은 경우 라. 영 제30조제1항제4호에 따라 개인정보를 안전하게 저장·전송하는데 필요한 조치를 하지 않은 경우 마. 영 제30조제1항제5호에 따라 개인정보 침해사고 발생에 대응하기 위한 접속기록의 보관 및 위조·변조 방지를 위한 조치를 하지 않은 경우 바. 영 제30조제1항제6호에 따라 개인정보처리시스템 및 개인정보 취급자가 개인정보 처리에 이용하는 정보기기에 컴퓨터 바이러스, 스파이웨어, 랜섬웨어 등 악성프로그램의 침투 여부를 항상 점검·치료할 수 있도록 하는 등의 기능이 포함된 프로그램의 설

	치·운영과 주기적 갱신·점검 조치를 하지 않은 경우 사. 영 제30조제1항제7호에 따라 개인정보의 안전한 보관을 위한 보관시설의 마련 또는 잠금장치의 설치 등 물리적 조치를 하지 않은 경우 아. 영 제30조제1항제8호에 따라 그 밖에 개인정보의 안전성 확보를 위하여 필요한 조치를 하지 않은 경우 자. 영 제29조의5제1항제2호에 따라 가명정보와 추가정보를 분리 보관하지 않은 경우 차. 영 제29조의5제1항제3호에 따라 가명정보와 추가정보에 대한 접근 권한을 분리하지 않은 경우 <공공시스템 운영기관 등의 경우> 가. 영 제30조의2제1항제1호에 따라 내부 관리계획에 공공시스템별로 작성한 안전성 확보 조치를 포함하지 않은 경우 나. 영 제30조의2제1항제2호에 따라 공공시스템이용기관이 정당한 권한을 가진 개인정보취급자에게 접근 권한을 부여·변경·말소 등을 할 수 있도록 하는 등 접근 권한의 안전한 관리를 위해 필요한 조치를 하지 않은 경우 다. 영 제30조의2제1항제3호에 따라 개인정보에 대한 불법적인 접근 및 침해사고 방지를 위한 공공시스템 접속기록의 저장·분석·점검·관리 등의 조치를 하지 않은 경우 라. 영 제30조의2제2항에 따라 공공시스템운영기관 및 공공시스템이용기관이 정당한 권한 없이 또는 허용된 권한을 초과하여 개인정보에 접근한 사실이 확인되는 경우에도, 지체 없이 정보주
--	--

	체에게 해당 사실과 피해 예방 등을 위해 필요한 사항을 통지하지 않은 경우 마. 영 제30조의2제3항에 따라 공공시스템운영기관(공공시스템을 개발하여 배포하는 기관이 따로 있는 경우에는 그 공공기관을 포함한다)이 해당 공공시스템의 규모와 특성, 해당 공공시스템이 용기관의 수 등을 고려하여 개인정보의 안전한 관리에 관련된 업무를 전담하는 부서를 지정하여 운영하거나 전담인력을 배치하지 않은 경우 바. 영 제30조의2제4항에 따라 공공시스템운영기관(공공시스템을 개발하여 배포하는 기관이 따로 있는 경우에는 그 공공기관을 포함한다)이 공공시스템별로 해당 공공시스템을 총괄하여 관리하는 부서의 장을 관리책임자로 지정(해당 공공시스템을 총괄하여 관리하는 부서가 없을 때에는 업무 관련성 및 수행능력 등을 고려하여 해당 공공시스템운영기관의 관련 부서의 장 중에서 지정) 하지 않은 경우 사. 영 제30조의2제5항에 따라 공공시스템운영기관이 공공시스템에 대한 안전성 확보 조치 이행상황 점검 및 개선에 관한 사항을 협의하기 위하여 공공시스템운영협의회를 설치·운영하지 않은 경우
영 별표2 제2호 저목	가. 법 제28조의5제2항(제26조제8항에 따라 준용되는 경우를 포함한다)을 위반하여 개인을 알아볼 수 있는 정보가 생성되었음에도 이용을 중지하지 아니한 경우 나. 법 제28조의5제2항(제26조제8항에 따라 준용되는 경우를 포함한다)을 위반하여 개인을 알아볼 수 있는 정보가 생성되었음에

	도 이를 회수·파기하지 아니한 경우
--	---------------------

※ 참고 : 법 및 영 등 개정으로 제3호의 위반행위별 각 목의 세부기준이 변경되는 경우에는 개정된 법령을 따른다.